Risk Treatment Process and Plan

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This document defines the process by which Stark Industries Inc. selects and implements appropriate information security controls to treat identified risks. It also provides a framework for developing, approving, and monitoring Risk Treatment Plans (RTPs) in accordance with ISO/IEC 27001:2022 Clause 6.1.3.

Scope

This process applies to all risks identified as unacceptable during the risk assessment phase and covers all information assets, operations, and systems within the ISMS scope.

Risk Treatment Objectives

- Reduce information security risks to acceptable levels
- Ensure selected controls are proportionate and effective
- Document and track all treatment actions
- Integrate treatment into business operations

Risk Treatment Options

For each unacceptable risk, one or more of the following options will be applied:

Option	Description
Mitigate	Apply controls to reduce the likelihood and/or impact
Avoid	Discontinue the activity that causes the risk
Transfer	Shift the risk to a third party (e.g. via insurance, contracts)
Accept	Acknowledge the risk when within the organisation's risk tolerance

Control Selection

Controls are selected based on:

- Risk severity
- Nature of the asset and threat
- Business context and resource availability
- ISO/IEC 27001:2022 Annex A control catalogue

Controls may also include custom or industry-specific measures. All selected controls are documented and justified in the Statement of Applicability (SoA).

Risk Treatment Plan (RTP)

Each Risk Treatment Plan includes:

Field	Description
Risk ID	Unique reference to the assessed risk
Asset	Associated information asset
Risk Description	Nature of the risk
Risk Level	Risk score before treatment
Treatment Option	Selected treatment strategy (mitigate, avoid, transfer, accept)
Selected Controls	Specific Annex A (or custom) controls applied
Residual Risk	Risk level after controls are applied
Responsible Person	Assigned risk owner or implementer
Target Completion Date	Planned date for control implementation
Status	Open / In Progress / Complete

Residual Risk and Acceptance

Once treatment is complete, residual risk is re-evaluated:

- If residual risk is acceptable, no further action is required.

- If residual risk exceeds the threshold, it must be formally accepted by top management (e.g. CEO), and this acceptance must be documented.

Monitoring and Review

Risk treatment plans are:

- Reviewed monthly by the Information Security Manager
- Tracked using a risk treatment log or dashboard
- Validated during internal audits and management reviews

Control effectiveness is tested through technical evaluations, user feedback, and incident monitoring.

Roles and Responsibilities

Role	Responsibilities
Information Security Manager	Oversees treatment planning, validates control effectiveness
Cyber Security GRC Analyst	Maintains RTPs, coordinates updates and documentation
Risk Owners	Ensure implementation of assigned controls
Top Management (CEO)	Approves residual risk acceptance where required

Related Documents

- Asset Inventory
- Risk Assessment Process
- Risk Register
- Statement of Applicability (SoA)
- Residual Risk Acceptance Log

- Internal Audit Reports
- Control Implementation Logs